

Http Y Burp

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Cookie de sesion
- Authorization Bearer
- rutas /api
- respuestas JSON
- Set-Cookie
- Authorization: Bearer

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>curl -i \$URL/</code>	Establece una respuesta HTTP base fuera del navegador para comparar status y cabeceras.	Status, cabeceras y cuerpo de referencia.
<code>curl -sS \$URL/swagger.json</code>	Busca un contrato OpenAPI publicado.	Listado de rutas, metodos y esquemas.
<code>curl -sS -i -X OPTIONS "\$URL/api/resource"</code>	Comprueba metodos aceptados por un recurso.	Cabeceras Allow y respuesta del endpoint.
<code>curl -sS "\$URL/api/me" -H "Authorization: Bearer \$TOKEN"</code>	Verifica el contexto de identidad actual.	Perfil o respuesta autenticada.
<code>curl -sS -i "\$URL/api/me"</code>	Compara el endpoint sin credenciales.	401/403 o respuesta publica.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.

- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.